

Gruppenaufgabe 2 | Vertiefte Datenklassifizierung und Datenhaltungskonzepte

Szenario

Die «HelveticFinance AG» ist ein mittelständischer Finanzdienstleister. Kürzlich gab es einen Audit-Mangel, da Kundendaten, Marketingbroschüren und historische Buchhaltungsdaten unsortiert auf denselben teuren Hochleistungsservern lagen und alle gleichermassen ohne Löschkonzept gesichert wurden. Als Projektleitung für Data Governance müssen Sie ein neues Datenhaltungskonzept einführen, um rechtliche Vorgaben zu erfüllen und Speicherkosten zu senken.

Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Unternehmensdaten nach den Dimensionen Verfügbarkeit, Sicherheit und Aufbewahrung klassifizieren.
- Lebenszyklen für verschiedene Datenkategorien definieren und daraus technische Speichervorgaben ableiten.
- Herausforderungen bei der praktischen Umsetzung der Datenklassifizierung bewerten.

Arbeitsauftrag

Entwickeln Sie für die «HelveticFinance AG» ein initiales Datenhaltungskonzept. Klassifizieren Sie drei beispielhafte Datenarten (Kreditdossiers, Werbeflyer, E-Mail-Postfächer) anhand der besprochenen Parameter. Legen Sie verbindliche Vorgaben fest, wie und wo diese Daten gespeichert, gesichert und wann sie gelöscht werden müssen.

Ergebnis

Erstellen Sie ein strukturiertes Plakat oder digitales Whiteboard, das Ihre Klassifizierungsmatrix zeigt und präsentieren Sie Ihre abgeleiteten technischen Massnahmen in einem Pitch von maximal 4 Minuten.

Musterlösung A | Gruppenaufgabe 2 | Vertiefte Datenklassifizierung und Datenhaltungskonzepte

Ansatz: Strukturiert-analytisch

1. Einleitung und Methodik

Die strukturierte Klassifizierung von Daten ist für die «HelveticFinance AG» nicht nur eine Frage der Kosteneffizienz, sondern primär eine rechtliche Notwendigkeit (Compliance). Um den

Mangel des letzten Audits strukturiert zu beheben, wenden wir eine dreidimensionale Bewertungsmatrix an. Die Parameter sind Verfügbarkeit (V), Sicherheit (S) und Aufbewahrung (A). Aus den resultierenden Klassen leiten wir im Anschluss die verbindlichen IT-technischen Vorgaben ab.

2. Klassifizierungsmatrix der «HelveticFinance AG»

Datenkategorie 1: Laufende Kreditdossiers

- **Verfügbarkeit:** Hochverfügbarkeit. Kundenbetreuer benötigen permanenten Zugriff auf diese Daten, um das Tagesgeschäft abzuwickeln.
- **Sicherheit:** Streng-Geheim/Vertraulich. Die Dossiers enthalten hochsensible personenbezogene Finanzdaten.
- **Aufbewahrung:** Langfristig. Nach Abschluss des Kredits greift eine gesetzliche Aufbewahrungspflicht von 10 Jahren gemäss Schweizer Obligationenrecht (OR).
- **Abgeleitete Vorgaben:** Speicherung im aktiven Zustand auf schnellen All-Flash-Storages mit AES-256 Verschlüsselung. Tägliche inkrementelle Backups. Nach Abschluss des Kredits: Verschiebung in ein revisionssicheres (WORM - Write Once Read Many) Langzeitarchiv.

Datenkategorie 2: E-Mail-Postfächer der Mitarbeitenden

- **Verfügbarkeit:** Standardverfügbarkeit. Ein Ausfall des Mailservers für einige Stunden ist ärgerlich, stoppt das Kerngeschäft aber nicht sofort.
- **Sicherheit:** Intern. Die E-Mails dürfen das Firmennetzwerk nicht unkontrolliert verlassen, sind aber in der Regel nicht extrem geheim (Ausnahme: Geschäftsleitung).
- **Aufbewahrung:** Mittelfristig. Nach Austritt eines Mitarbeitenden oder nach Ablauf von 5 Jahren werden alte E-Mails routinemässig gelöscht, sofern sie keine Geschäftsverträge beinhalten.
- **Abgeleitete Vorgaben:** Speicherung auf kostengünstigerem Tier-2 Storage (z. B. SAS-Festplatten). Tägliche Backups. Implementierung eines Data-Loss-Prevention (DLP) Tools, das den Versand von Anhängen mit Kreditkartennummern nach aussen blockiert.

Datenkategorie 3: Werbeflyer und Marketingmaterialien

- **Verfügbarkeit:** Basisverfügbarkeit.
- **Sicherheit:** Öffentlich. Die Dokumente sind explizit für die Veröffentlichung gedacht.
- **Aufbewahrung:** Kurzfristig. Veraltete Kampagnen können gelöscht werden, um Speicherplatz zu sparen. Eine historische Aufbewahrung erfolgt maximal für das eigene Firmenarchiv.
- **Abgeleitete Vorgaben:** Speicherung auf günstigen Cloud-Speichern oder NAS-Systemen ohne aufwändige Verschlüsselung. Wöchentliche Backups reichen aus.

3. Implementierung und Bewältigung von Herausforderungen

Die rein theoretische Matrix muss nun in den operativen IT-Betrieb der «HelveticFinance AG»

integriert werden.

- **Problem der Subjektivität:** Wenn man die Fachabteilungen fragt, stufen diese oft alle ihre Daten als "Hochverfügbar" und "Vertraulich" ein.
- **Lösungsvorgabe:** Die IT gibt klare Budgets pro Abteilung vor. Teurer Tier-1 Storage wird intern verrechnet (Chargeback-Verfahren). Dies zwingt die Abteilungsleiter, realistisch zu klassifizieren.
- **Automatisierung:** Die manuelle Klassifizierung schlägt in der Praxis oft fehl, weil Anwender das Setzen von Metadaten vergessen. Wir implementieren ein Office-Plugin, das beim Speichern zwingend nach der Vertraulichkeitsstufe fragt, ohne die sich das Dokument nicht sichern lässt.

4. Fazit

Das erarbeitete Datenhaltungskonzept sorgt dafür, dass die teuren und hochverfügbaren Speichersysteme der «HelveticFinance AG» ab sofort exklusiv für sensible und kritische Kerndaten (wie Kreditdossiers) reserviert bleiben. Veraltete oder unwichtige Daten durchlaufen einen definierten Lebenszyklus und werden schlussendlich rechtskonform vernichtet. Der Audit-Mangel ist damit vollständig behoben.

Musterlösung B | Gruppenaufgabe 2 | Vertiefte Datenklassifizierung und Datenhaltungskonzepte

Ansatz: Praxisnah-narrativ

1. Die Realität der Datenflut

Stellen Sie sich vor, Sie betreten das Archiv der «HelveticFinance AG». Im Moment sieht es aus wie eine riesige Halle, in der Tresore, Altpapier, geheime Akten und leere Kaffeekartons auf einem gigantischen Haufen liegen. Die IT baut einen immer grösseren, teureren Zaun um diesen Haufen, weil sie nicht weiss, was darin liegt. Genau das hat der Auditor bemängelt: Wir speichern alles auf den teuersten Flash-Laufwerken und sichern es täglich, als wäre jede Datei überlebenswichtig für die Bank. Unser neues Datenhaltungskonzept bringt nun Ordnung in dieses Chaos.

2. Der Lebenszyklus der Bankdaten (Szenario-Durchsprache)

Wir haben uns mit den Stakeholdern an einen Tisch gesetzt und exemplarische Datenflüsse durchgespielt, um praxisnahe Regeln zu etablieren.

Das Kreditdossier:

Ein Kunde beantragt eine Hypothek. In dem Moment, in dem die Sachbearbeiterin das Dokument anlegt, ist es heiss. Es benötigt **Hochverfügbarkeit** (der Kunde wartet auf Antwort)

und extreme **Sicherheit** (Lohnausweise, Schulden). Wir legen es auf unserem besten, internen Speicher ab. Nach drei Monaten ist der Kredit bewilligt und läuft. Das Dokument wird kalt. Es muss nicht mehr in Millisekunden verfügbar sein, aber es muss sicher aufbewahrt werden. Hier greift unser **Retention-Management**: Die IT verschiebt das Dossier automatisch auf einen günstigeren, aber absolut sicheren (WORM) Archivspeicher. Dort bleibt es für 10 Jahre unveränderbar liegen. Danach löscht das System das Dossier restlos und stellt ein Vernichtungszertifikat aus.

Die E-Mails:

Wir ertrinken in E-Mails. Die Fachabteilungen nutzen Outlook als privates Dateiarchiv. Unsere Vorgabe lautet nun: E-Mails haben **Standardverfügbarkeit** und sind **Intern**. Wir verschieben alle Postfächer auf kostengünstige, grosse Festplatten-Arrays. Was passiert nach fünf Jahren? Wir setzen ein Verfallsdatum. Alles, was älter als fünf Jahre ist und nicht manuell durch den User mit dem Metadatum "Rechtlich relevant" markiert wurde, wird vom System gelöscht. Das zwingt die Mitarbeitenden, wichtige geschäftliche Beschlüsse aus den E-Mails in das richtige Dokumenten-Management-System zu überführen.

Das Marketing-Material:

Der neue Prospekt für die Altersvorsorge ist **Öffentlich** und erfordert nur **Basisverfügbarkeit**. Es macht überhaupt keinen Sinn, diesen Prospekt mit den gleichen teuren Verschlüsselungsalgorithmen zu sichern wie die Hypothekenverträge. Wir lagern diesen Bereich auf ein einfaches Laufwerk aus. Wenn das Laufwerk kaputtgeht, spielen wir in Ruhe das wöchentliche Backup zurück.

3. Change Management – Wie nehmen wir die Leute mit?

Der schwierigste Teil dieses Konzepts ist nicht die Technik, sondern der Mensch. Niemand löscht gerne Daten.

- Wir setzen auf Tool-Unterstützung im Hintergrund. Wir wollen den Sachbearbeiter nicht mit Formularen zur Datenklassifizierung quälen. Unser neues Scanner-Tool durchsucht nachts die Ablagesysteme. Erkennt das Tool eine AHV-Nummer oder Kontoverbindung, verschiebt es die Datei automatisch in den verschlüsselten, gesicherten Bereich.
- Wir führen "Aufräum-Freitage" ein. Das Management unterstützt uns dabei. Zweimal im Jahr gibt es einen Nachmittag, an dem die Teams ihre Verzeichnisse durchgehen und Altlasten physisch aus dem aktiven System werfen.

4. Schlusswort

Das neue Datenhaltungskonzept der «HelveticFinance AG» spart uns im nächsten Jahr rund 30% an Speicherkosten, da wir teuren Tier-1-Storage freischaufeln. Noch wichtiger ist jedoch, dass wir im nächsten Audit genau nachweisen können, wo unsere sensibelsten Kundendaten

liegen, wer darauf zugreift und wann sie rechtskonform vernichtet werden.